You said:

exec.pyc
Code

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Worked for 2m 24s

ChatGPT said:

Análise estática de malware — `exec.pyc`

Veredito preliminar: MALWARE

A análise do bytecode Python já revelou comportamentos maliciosos: o programa baixa uma extensão do Chrome de um endereço externo, altera configurações internas do navegador para registrá-la e modifica os códigos de integridade usados para proteger essas configurações.

A inspeção foi realizada **sem executar o arquivo**. O objetivo é reconstruir seu comportamento a partir das instruções compiladas e das constantes embutidas.

1. Identificação do arquivo

Propriedade	Resultado
Arquivo analisado	`exec.pyc`
Formato	Bytecode Python compilado
Versão identificada	CPython 3.13
Tamanho	12.336 bytes
SHA-256	`0e2d54cf86bb9d0d0cd02ed601be2df15a79d9a4927c82af61e0b0f666bc5941`
Execução durante a análise	Não realizada

O SHA-256 permite identificar precisamente esta amostra e compará-la com registros de ferramentas de segurança.

2. Bibliotecas utilizadas

O programa importa bibliotecas e módulos que revelam suas principais capacidades:

Biblioteca	Finalidade observada
`requests`	Fazer requisições HTTP para baixar arquivos e enviar notificações.
`zipfile`	Extrair uma extensão a partir de um arquivo ZIP.
`psutil`	Enumerar processos e encerrar o Chrome.
`win32api` e `win32security`	Obter o usuário atual e informações da conta do Windows.
`json` e `OrderedDict`	Ler e alterar as preferências do Chrome.
`hmac` e `hashlib`	Calcular códigos de integridade para manipular as proteções do navegador.
`os` e `tempfile`	Acessar caminhos locais e criar diretórios temporários.

O conjunto dessas bibliotecas não caracteriza malware por si só. A evidência relevante é a combinação dessas funcionalidades com as alterações específicas que o código realiza.

3. Reconstrução do comportamento, passo a passo

Etapa 1 — Encerra os processos do Chrome

A função `fechar_chrome()` percorre os processos do sistema, procura nomes que contenham `chrome`, solicita o encerramento desses processos e espera até cinco segundos.

Por que isso é suspeito?

O arquivo `Secure Preferences` pode ser alterado com mais facilidade quando o navegador não está em execução. O encerramento do Chrome prepara o ambiente para a manipulação das configurações protegidas.

Etapa 2 — Identifica o usuário do Windows

O programa utiliza:

- `win32api.GetUserName()` para consultar o nome da conta.
- `win32security.LookupAccountName()` para obter informações de segurança da conta.

- `win32security.ConvertSidToStringSid()` para converter o identificador de segurança (SID).

Ele também obtém o nome de usuário por meio de `os.getlogin()` e usa essas informações nas etapas seguintes.

A obtenção do SID tem uma finalidade técnica importante: o identificador é incorporado aos cálculos de integridade das configurações do Chrome.

Etapa 3 — Baixa uma extensão de origem externa

A função `download_and_extract_extension()` baixa um arquivo ZIP do seguinte endereço incorporado ao código:

```
https://antiddos-protection.net/_____________/chrome_extension.zip
```

O procedimento é:

1. Criar um diretório temporário.
2. Fazer uma requisição HTTP para o endereço configurado.
3. Salvar a resposta como `chrome_extension.zip`.
4. Extrair o conteúdo para um subdiretório temporário.
5. Retornar o caminho da extensão extraída.

Não há verificação de autenticidade, assinatura digital ou hash esperado do arquivo baixado no fluxo identificado. A checagem do código exige apenas um status HTTP `200`.

Indicador de risco: o programa obtém e prepara um componente executável de navegador a partir de um servidor externo, sem demonstrar que a origem é confiável.

Etapa 4 — Calcula um identificador para a extensão

A função `get_extension_id()` calcula um SHA-256 a partir do caminho da extensão, converte os caracteres hexadecimais para letras de `a` a `p` e utiliza os primeiros 32 caracteres resultantes.

Esse identificador é usado para inserir uma entrada na estrutura de configurações do Chrome.

O método é suspeito nesse contexto porque participa de uma instalação automatizada, e não de um fluxo normal de instalação pelo usuário. Não confirmei, porém, que o identificador calculado corresponde ao identificador real da extensão dentro do ZIP.

Etapa 5 — Prepara os dados de instalação

O programa monta uma entrada JSON contendo configurações como estas:

Campo	Valor definido pelo programa
`from_webstore`	`false`
`incognito`	`true`
`newAllowFileAccess`	`true`
`active_permissions.api`	`cookies`, `storage`, `tabs`, `scripting`
`granted_permissions.api`	`cookies`, `downloads`, `storage`, `tabs`
`explicit_host`	`*` para corresponder a todos os URLs, representado no código como `<all_urls>`
`serviceworkerevents`	`tabs.onUpdated`
`location`	`4`
`path`	Caminho do diretório temporário extraído

Esses campos indicam uma tentativa de registrar a extensão com capacidades relevantes para a navegação e o acesso a dados do navegador.

Em particular, as permissões declaradas de `cookies`, acesso a abas e abrangência de URLs representam um risco significativo. **Elas não provam que o componente rouba cookies ou senhas**, mas permitem concluir que a extensão pretendida teria acesso privilegiado a atividades do navegador, conforme as permissões efetivamente concedidas pelo Chrome.

Etapa 6 — Modifica as preferências protegidas do navegador

Essa é uma das evidências mais fortes da análise.

O arquivo acessado pelo programa é:

`C:\Users\<usuário>\AppData\Local\Google\Chrome\User Data\Default\Secure Preferences`

O programa lê seu conteúdo JSON e adiciona a entrada em:

`extensions.settings.<identificador_da_extensão>`

Em seguida, altera também:

```
extensions.ui.developer_mode = true
```

Ou seja, o código tenta registrar a extensão diretamente no perfil do navegador, em vez de depender do procedimento convencional de instalação pela loja ou de uma ação explícita do usuário.

A documentação do Chromium descreve justamente os arquivos de preferências e as verificações de integridade envolvidas nesse tipo de configuração. O MITRE ATT&CK também documenta o abuso de extensões de navegador como técnica de persistência e acesso. Chromium +2

Etapa 7 — Recalcula os códigos de integridade para ocultar a adulteração

O programa inclui três funções particularmente reveladoras:

- `calculateHMAC()`
- `calculate_chrome_dev_mac()`
- `calc_supermac()`

Elas calculam códigos HMAC-SHA256 usando uma sequência fixa de bytes, o SID do usuário, os caminhos das preferências e os valores a serem registrados.

O programa grava os resultados em entradas de `protection.macs`, incluindo o código associado à extensão, o código da preferência de modo desenvolvedor e o campo global `super_mac`.

Isso é muito mais grave do que simplesmente editar um arquivo JSON: o objetivo aparente é atualizar também os códigos que o navegador utiliza para detectar alterações nas preferências protegidas.

A técnica se alinha ao abuso conhecido de `Secure Preferences` para carregar extensões de forma silenciosa em sistemas já comprometidos. Chromium +1

Etapa 8 — Sobrescreve o arquivo e tenta concluir a instalação

Após alterar os dados, o programa:

1. Grava as configurações modificadas em `Secure Preferences`.
2. Reabre o arquivo e calcula o `super_mac`.
3. Grava novamente o JSON com o código global atualizado.
4. Exibe a mensagem `Extensão instalada com sucesso!`.

A sequência demonstra uma tentativa de produzir uma configuração de instalação internamente consistente. Isso não garante que a extensão será aceita ou executada: o sucesso depende, entre outros fatores, da versão do Chrome, da estrutura do perfil, do ZIP baixado e da compatibilidade do identificador e dos códigos de integridade.

Etapa 9 — Envia uma notificação para um serviço externo

Por fim, `notificar_instalacao()` envia uma requisição HTTP POST para um tópico do serviço `ntfy.sh`:

```
https://ntfy.sh/crimeorganizado000000000000caiunoob
```

O texto da mensagem inclui o identificador da extensão e o nome do usuário.

Isso constitui um canal de comunicação externo que pode informar a um operador que o procedimento foi executado. O código observado não demonstra, por si só, o envio de senhas, cookies ou histórico de navegação por essa função específica.

4. Indicadores de comprometimento (IOCs)

Os seguintes indicadores foram extraídos diretamente do arquivo analisado:

Indicador	Valor
Arquivo	`exec.pyc`
SHA-256	`0e2d54cf86bb9d0d0cd02ed601be2df15a79d9a4927c82af61e0b0f666bc5941`
URL para download	`https://antiddos-protection.net/_____/chrome_extension.zip`
Serviço de notificação	`ntfy.sh`
Perfil afetado	`Chrome\User Data\Default\Secure Preferences`
Funções relevantes	`download_and_extract_extension`, `add_extension`, `calculateHMAC`, `calc_supermac`

O MITRE ATT&CK classifica o abuso de extensões de navegador como a técnica **T1176.001 — Browser Extensions**, que pode ser utilizada para manter acesso e executar atividades maliciosas por meio do navegador. MITRE ATT&CK®

5. Limitações e impacto potencial

Há três ressalvas importantes para interpretar o resultado corretamente.

Primeira: o ZIP da extensão não foi incluído na amostra analisada. Portanto, não foi possível verificar o comportamento interno dos scripts da extensão. As permissões declaradas sugerem capacidade de acessar dados do navegador, mas não comprovam, isoladamente, roubo de credenciais.

Segunda: o código implementa os cálculos de integridade tradicionais, mas não contém o tratamento dos hashes criptografados mais recentes usados na proteção de preferências do Chrome. O Chrome 144 introduziu um sistema reforçado de proteção contra adulteração de preferências para navegadores Windows gerenciados. Assim, a eficácia da técnica pode variar de acordo com a versão e a configuração do navegador.

Google Clou... +1

Terceira: a análise é estática. Ela confirma que o programa contém instruções para realizar as ações descritas, mas não demonstra que o download, a instalação ou a comunicação externa tenham sido concluídos com sucesso em uma máquina real.

Se o arquivo já foi executado, recomendo isolar o computador da rede, verificar as extensões instaladas no Chrome e realizar uma varredura com uma ferramenta de segurança confiável. Como existe potencial acesso a cookies e outros dados de navegação, também é prudente encerrar sessões e alterar senhas importantes a partir de um dispositivo confiável.

6. Veredito final

MALWARE — alta confiança

Categoria principal: Trojan do tipo *downloader/instalador de extensão maliciosa para navegador*.

Justificativa decisiva: o arquivo combina download de código externo, encerramento do Chrome, modificação direta de `Secure Preferences`, tentativa de falsificar os códigos de integridade do navegador e envio de uma notificação externa sobre a instalação.

Esse conjunto de ações é incompatível com o comportamento esperado de um instalador legítimo comum. Mesmo que a técnica não funcione em determinada versão do Chrome, a intenção operacional demonstrada pelo bytecode é maliciosa.

Conclusão: o arquivo não deve ser considerado benigno nem executado em um computador de uso pessoal ou corporativo.

Também posso criar um ↪ diagrama visual do fluxo.

You said:

Qual é a categoria principal deste malware?

ChatGPT said:

A categoria principal deste malware é **Trojan (Cavalo de Troia), do tipo downloader/instalador de extensão maliciosa para navegador**.

Seu comportamento também apresenta características de **Browser Hijacker** (sequestrador de navegador), pois tenta instalar uma extensão silenciosamente, adulterando as preferências protegidas do Google Chrome.

Classificação principal: Trojan — instalador de extensão maliciosa.